

Project Two Recommendation Report

William Pascoe

CYB-240: Application Security

Stephen Hoover

February 21, 2026

Project Two Recommendation Report

I have reviewed the system specifications for the new web application that is going to be developed. There are some concerns that I have that if not properly addressed the application could be vulnerable to several types of cybersecurity attacks. These concerns I will be talking about are dealing with HTTP protocols and client-side scripting.

Communication to the web server is done via the internet. In its current state this will be done using HTTP protocols. According to OWASP, which is the Open Worldwide Application Security Project, this is not the best practice to use. The reason for this is because when data is transmitted over http it is transmitted in plain text and not encrypted. This makes the data easily captured from a man in the middle attack or even someone sniffing packet data using a network tool like Wireshark. The standard that OWASP recommends, based on their top ten security risks, is to have the data encrypted. When using cryptography protocols and transmitting data over https it will be secure from attacks because if they were to try to steal the data using the means described above, they would then have to figure out how to unencrypt the data that they were able to obtain.

When implementing data in transit encryption we want to use what is known as Transport Layer Security, or TLS, When using these security measures with things like disabling http and enforcing a content security policy we will ensure that our sensitive data is secured with a high level of encryption and not subject to being easily gathered and read.

The next concern that I will address is login to the web server via client-side scripting. Having access control to a web application is a definite must but it cannot be done with client-side scripting. This practice allows attackers to easily bypass the authentication process by using

cross site scripting and talking directly to the server. All access control must be based on the server and requests sent from the client side. Using this practice ensures that authentication is done at the proper level and with more secure practices. OWASP recommends using this method of access control. Another practice that is recommended by OWASP when it comes to access control is least privilege. This ensures that people only have access to the data that they need to have access to and nothing else. This is the best practice because if something a hacker obtains login credentials, they will be able to access the entire system. It also prevents employees from accessing data that they should not have access to as well.

To implement access control, we must use role-based access with the credentials stored on the server side. Role based access, as described above, would work best in this type of application because different people using the application would have different jobs and need access to various parts of the data set. The system should also use practice of denying by default. If it is unsure whether someone has access to certain parts of the systems, it should automatically deny and let an admin determine whether to add access or not. This is considered best practice because it adheres to the principle of least privilege.

When it comes to the software development life cycle it can be beneficial to have a security practitioner as part of the team from the start of development. Many security features such as role-based access or using cryptography should be developed from the beginning of the project and not be an afterthought during the testing phase. If they are implemented at the end of the cycle, they are much harder to code in because it would cause most of it to be rewritten. Having knowledge of basic security principles and keeping them in mind as the project is developed will ensure that the application is done right the first time, which saves time in the

end, and developed securely to prevent malicious attacks on the data that the application is trying to protect.

References:

Harwood, M., & Price, R. (2022). *Internet and Web Application Security*. Jones & Bartlett Learning.

Introduction - OWASP Top 10 Proactive Controls. (2024). *Owasp.org*.

<https://top10proactive.owasp.org/the-top-10/>